

계정관리 지침



주식회사 모인

개정 이력

[illegible]

계정관리 지침

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 지침은 주식회사 모인(이하 "회사"라 한다)에서 운영하는 정보시스템 및 응용프로그램의 계정관리, 비밀번호 관리 및 권한관리에 대해 정보보호에서 필요한 관리 업무를 체계적으로 수행함을 그 목적으로 한다.

제2조(적용 범위) 이 지침은 회사 내의 업무계정 및 접근권한을 관리하는 업무담당자 및 사용자를 대상으로 한다.

제3조(용어의 정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.

- 1 “접근권한”이란 사용자 및 그룹별로 정보시스템/응용프로그램에 접근 및 수행할 수 있는 작업 권한을 말한다.
- 2 “관리자 및 특수권한”이란 정보시스템/응용프로그램의 일반 사용자의 계정 및 접근권한을 부여·말소·제한할 수 있는 권한을 말한다.

제2장 역할 및 책임

제4조(정보보호 담당자)

- 1 정보보호 담당자는 관리자 및 특수권한 계정의 생성 및 권한 부여의 적정성을 검토할 책임을 가진다.
- 2 정보보호 담당자는 시스템 담당자가 계정의 생성 및 권한 부여 시 이 지침에서 규정된 사항을 적절히 이행하고 있는지 관리할 책임과 권한을 가진다.

제5조(시스템 담당자)

- 1 시스템 담당자는 정보시스템/응용프로그램의 사용자 계정의 생성·변경·폐기에 대한 책임을 가진다.
- 2 시스템 담당자는 정보시스템/응용프로그램에 대해 권한 부여의 적정성을 검토하고 관리할 책임을 가진다.

제3장 사용자 계정 관리

제6조(계정 생성)

- 1 회사는 임직원에게 부여하는 정보시스템/응용프로그램의 인증 수단을 사용자 계정을 사용하는 개인별로 부여하여야 한다. 다만, 업무상 불가피하게 공용 계정을 사용하는 경우 정보보호 담당자의 승인을 받은 후 생성하고, 개인별 사용내역을 기록·관리하여야 한다.
- 2 정보시스템/응용프로그램의 계정이 필요한 계정신청자는 계정 발급 신청/승인 절차를 따라야 한다.
- 3 시스템 담당자는 계정 요청에 대하여 다음 각 호의 사항을 참고하여 적정성 검토를 수행하고, 제2호 내지 제4호의 권한 부여에 대해서는 정보보호 담당자에게 통보하여야 한다.
 - 1) 직무 및 역할별 구분
 - 2) 개인정보취급자
 - 3) 정보시스템 관리자 권한(root, Administrators그룹, DBA권한부여 계정 등)
 - 4) 프로젝트 수행을 위한 외부직원 계정
- 4 시스템 담당자는 승인된 계정신청서를 지체 없이 처리하고 그 결과를 계정 신청자에게 통보하여야 한다.
- 5 시스템 담당자는 유지보수, 장애처리 등의 목적으로 외부직원이 사용할 임시계정은 작업에 필요한 최소한의 권한만 부여될 수 있도록 사용기간, 사용 목적, 담당자 등을 포함하여 계정 신청서를 작성하고 각 팀 리더의 승인을 받은 후 계정을 생성하여야 한다.

제7조(계정 관리)

- 1 업무상 불가피하게 공용 계정을 사용하는 경우 시스템 담당자는 다음 각 호의 보안대책을 마련하여야 한다.
 - 1) 공용계정의 관리책임자 지정
 - 2) 공용 계정의 사용자 목록 유지 관리
 - 3) 분기 1회 비밀번호 변경
 - 4) 공용 계정 사용자 변경 시 비밀번호 즉시 변경
- 2 시스템 담당자는 제8조 제2항과는 별개로 매월 정보시스템/응용프로그램에 등록된 계정 생성에 대한 적정성을 검토하여 정보보호 담당자에게 통보 후 다음 각 호에 해당하는 불필요한 계정을 삭제하거나 비활성화 처리를 하여야 한다.
 - 1) 90일 이상 미 접속 계정 비활성화
 - 2) 직무 변경 또는 퇴직자 계정 삭제
 - 3) 작업 및 프로젝트 수행으로 생성된 임시 계정 이용기간 만료 시 삭제
- 3 시스템 담당자는 등록된 정보시스템/응용프로그램의 관리자 및 특수권한 계정에 대하여 다음 각 호에 따라 관리하여야 한다.
 - 1) 관리자 및 특수권한 계정은 최소한의 인원에게만 부여해야 한다.
 - 2) 관리자 및 특수권한 계정은 일반 사용자 계정과 별도로 계정 목록을 작성하여 관리하여야 하며,

비인가자가 접근할 수 없도록 접근통제를 적용하여 안전한 곳에 보관하여야 한다.

- 3) 관리자 및 특수권한 계정의 주요 업무 관련 행위는 책임자가 이중확인 및 모니터링 하여야 한다.
- 4) 관리자 및 특수권한 계정은 월 1회 이상 권한의 적정성을 검토하여 정보보호 담당자에게 보고해야 한다.

제8조(계정 변경 및 삭제)

- 1 시스템 담당자는 정보시스템에 기본적으로 포함되어 있는 제품 공급 계정(Default 계정, Test 계정 등) 중 업무적으로 불필요한 계정을 삭제하는 등 보안조치를 수행하여야 한다.
- 2 시스템 담당자는 계정 사용자의 퇴직, 직무이동 등의 인사변동이 있을 때에는 지체 없이 사용자의 계정을 정지 또는 삭제하여야 한다.
- 3 시스템 담당자는 정보시스템 및 응용프로그램의 관리자와 특수권한 계정의 변경 또는 삭제 조치하였을 경우에는 계정목록에 반영하여야 한다.
- 4 시스템 담당자는 유지보수, 장애처리 등의 목적으로 외부직원에게 발급된 계정이 사용 목적을 달성한 경우 지체 없이 제거하여야 한다.

제9조(비밀번호 관리)

- 1 시스템 담당자는 신규 계정에 따른 초기 비밀번호 부여시 임의의 패턴으로 생성하여 사용자에게 통보하여야 하며, 사용자는 최초 로그인 시 비밀번호를 즉시 변경하여야 한다.
- 2 사용자는 비밀번호 생성·변경 시 안전한 비밀번호를 설정하여 이행할 수 있도록 다음 각 호의 규칙을 준수하여야 한다.
 - 1) 영문자, 숫자, 특수문자를 조합하여 2종류 조합 10자리 이상, 3종류 조합 8자리 이상 설정
 - 2) ID, 생년월일, 주민등록번호, 전화번호 등 유추하기 쉬운 문자열 사용 금지
 - 3) 비밀번호는 유효기간을 설정하여 분기 1회 이상 변경
 - 4) 중요 시스템의 경우 비밀번호 변경 시 최근 4개의 비밀번호 사용 금지 등(고객 정보가 존재하거나 처리되는 응용프로그램, DBMS, 서버 등에 적용)
- 3 관리자 비밀번호는 정보시스템/응용프로그램마다 다르게 설정하여야 한다.
- 4 시스템 담당자는 사용자의 비밀번호 분실 시 본인확인 절차를 거친 후 비밀번호를 초기화하여야 하며, 임의의 패턴으로 변경하여 사용자에게 통보하여야 한다.
- 5 시스템 담당자는 사용자 비밀번호의 안전한 관리를 위하여 다음 각 호의 사항에 따라 관리하여야 한다.
 - 1) 사용자의 비밀번호가 손실 또는 노출된 경우 비밀번호를 지체 없이 변경한다.
 - 2) 비밀번호는 화면상에 읽을 수 있는 형태로 표시되지 말아야 하며, 암호화된 형태로 저장하여야 한다.
(일방향 암호화 적용)

- 3)비밀번호 입력 시 5회 오류가 발생하는 경우 계정이 잠기도록 설정하여야 하며, 본인확인 절차를 거친 후 비밀번호를 초기화 하여야 한다.
- 4)비밀번호 관리에 대한 책임은 사용자에게 있음을 알려야 한다.

제4장 접근권한 부여 및 관리

제10조(접근권한 부여)

- 1 정보시스템/응용프로그램에 대한 접근권한은 다음 각 호의 사항을 고려하여 업무 수행에 필요한 최소한의 권한으로 한정하는 것을 원칙으로 한다.
 - 1)접근권한은 사용자, 직책, 부서, 업무 및 역할 등 세분화하여 필요한 권한만 부여하여야 한다.
 - 2)업무상 불필요한 경우 사용자가 서비스 중지 등을 일으킬 수 있는 명령어를 사용할 수 없도록 제한하여야 한다.
- 2 개인정보처리시스템에 대한 접근 권한을 부여하는 경우, 이용자의 개인정보가 최소한으로 노출될 수 있도록 통제하여야 한다.
- 3 개인정보처리시스템 내 출력 및 다운로드 등의 개인정보가 유출될 수 있는 기능의 사용 권한은 최소한의 사용자에게만 부여하여야 한다.

제11조(접근권한 관리)

- 1 시스템 담당자는 매월 접근권한에 대하여 다음 각 호의 사항을 기준으로 계정의 접근권한 적정성을 검토하고 정보보호 담당자에게 통보 후 계정 삭제 및 접근권한 회수 작업을 수행하여야 한다.
 - 1)장기간 미 접속 계정
 - 2)직무 변경 또는 퇴직 시 기존권한 회수
 - 3)휴직(병가, 출산 등) 시 계정 중지 및 권한 회수
 - 4)접근권한 과다 부여, 오남용 등
- 2 시스템 담당자는 사용자의 직무 변경이나 퇴직 시 해당 사용자 계정의 접근권한을 지체 없이 변경 또는 말소하여야 한다.
- 3 외부직원에게 관리자 권한 및 특수권한을 부여해서는 아니된다. 다만, 업무상 필요로 하는 경우에 한하여 한시적으로 부여할 수 있으며, 사용이 끝난 후에는 지체 없이 삭제하여야 한다.
- 4 정보보호 담당자는 월 1회 이상 접근권한관리 내역을 검토하여야 한다.
- 5 개인정보처리시스템에 대한 접근권한 부여, 변경 또는 말소에 대한 로그는 「정보시스템 보안지침」과 「응용프로그램 보안지침」에 따라 5년간 보관하여야 한다.
- 6 CISO는 접근권한 과다 부여 및 오남용의 이상징후가 발견된 경우에는 사용자에게 소명을 요청할 수 있으며, 정보보호 규정 위반이 발생한 경우 정보보호위원회를 통해 징계여부를 결정할 수 있다.

부칙

제1조(시행일) 이 지침의 시행일은 대표이사가 승인한 날로 한다.